

UNCLASSIFIED



National Geospatial-Intelligence Agency

INSTRUCTION

NGAI 8010.1

7 December 2021

Administrative Update 1, 15 March 2022

CIO-T

SUBJECT: Information Systems Risk Management Framework

References: See Enclosure 1.

1. PURPOSE. This Instruction:

a. Establishes policy and assigns responsibilities for NGA's Information Systems (ISs) Risk Management Framework (RMF).

b. Rescinds:

(1) NGA Directive 8010, "Information Systems Risk Management Framework (RMF)," 27 August 2015, Administrative Update, 16 November 2015.

(2) NGA Manual 8010.1, "Information Systems (IS) Risk Management Framework (RMF) Guide," 24 July 2015, Administrative Update 1, 06 December 2018.

2. APPLICABILITY. This Instruction applies to all NGA civilian employees, military service members, other Government agency personnel assigned to NGA, and contractors, hereinafter referred to as *personnel*.

3. DEFINITIONS. See Glossary.

4. POLICY. It is NGA policy to:

a. Use the RMF as a holistic and strategic process for the risk management of ISs through the use of common standards, risk assessment processes, and IS authorization to operate. (References (a) and (j))

b. Establish the Information Assurance Requirements Catalog (IARC), Reference (k), as the authoritative source for NGA's security control baselines, organizationally defined security control parameters, and designation of security controls as common, hybrid, or system-specific.

c. Use Common Control Providers (CCPs) and Enterprise Security Services (ESSs) to support the RMF. (References (c), (j), and (k))

UNCLASSIFIED

d. Require ~~Directorate Heads, Agency Element Leads~~ **Component Heads**, Program Managers (PMs), and Information System Owners (ISOs) to comply with References (a) through (l).

5. RESPONSIBILITIES. See Enclosure 2.

6. EFFECTIVE DATE. This Instruction is effective on the date of signature.

CHATELAIN.MAR
K.L.1268945535

Digitally signed by
CHATELAIN.MAR.K.L.1268945535
Date: 2021.12.07 13:21:38 -05'00'

Mark Chatelain
Associate Chief Information Officer

Enclosures

1. References
2. Responsibilities

Glossary

TABLE OF CONTENTS

CHANGE LOG	4
ENCLOSURE 1: REFERENCES	5
ENCLOSURE 2: RESPONSIBILITIES	6
Director, NGA	6
Chief Information Officer.....	6
Associate Chief Information Officer.....	6
Chief Information Security Officer	6
Deputy Chief Information Security Officer	6
Senior Accountable Official for Risk Management.....	6
Authorizing Officials	7
Delegated Authorizing Officials.....	8
Director, Chief Information Officer and Information Technology Services.....	8
Director, Security and Installations.....	9
Chief, NGA Operations Center Mission Assurance.....	9
Directorate Heads and Agency Element Leads Component Heads.....	9
Common Control Providers	9
Program Managers and Information System Owners	9
Information System Security Engineers	10
Information System Security Officers	10
GLOSSARY	11

CHANGE LOG

Change	Change Date	Revised By	Pages Affected	Change Description
1-1	3/15/2022	DXCI	2, 3, 9	Updated Directorates and Agency Elements to Components and Directorate Heads and Agency Element Leads to Component Heads.
1-2	3/15/2022	DXCI	3	Updated Table of Contents.
1-3	3/15/2022	DXCI	5	Updated references.
1-4	3/15/2022	OPR	9	Removed Chief, NGA Operations Center–Mission Assurance’s responsibility.
1-5	3/15/2022	OPR	14	Adjusted definition

ENCLOSURE 1REFERENCES

- (a) Intelligence Community Directive ~~(ICD)~~ 503, "Intelligence Community Information Technology Systems Security Risk Management," 15 September 2008, Technical Amendment, 21 July 2015
- (b) Intelligence Community Standard 503-03, "Implementing the Risk Management Framework for Intelligence Community Information Systems," 15 February 2017 (U//FOUO)
- (c) Intelligence Community Chief Information Officer, "ICD 503 Practitioner Manual," 29 January 2013
- (d) Committee on National Security Systems Instruction (CNSSI) No. 1253, "Security Categorization and Control Selection for National Security Systems," 27 March 2014
- (e) CNSSI ~~No.~~ 4009, "Committee on National Security Systems (CNSS) Glossary," ~~06 April 2015~~ 02 March 2022
- (f) National Institute of Standards and Technology (NIST) Special Publication (SP) 800-37, Revision 2, "Risk Management Framework for Information Systems and Organizations: A System Life Cycle Approach for Security and Privacy," 20 December 2018
- (g) NIST SP 800-137, "Information Security Continuous Monitoring (ISCM) for Federal Information Systems and Organizations," 30 September 2011
- (h) Federal Information Processing Standards (FIPS) Pub 199, "Standards for Security Categorization of Federal Information and Information Systems," February 2004
- (i) NGA Instruction 8120.1, "Electronic Waste Management," 01 September 2020
- (j) "The National Geospatial Intelligence Agency (NGA) Intelligence Community Directive (ICD) 503 Risk Management Framework (RMF) Implementation Guide," current version
- (k) Information Assurance Requirements Catalog (IARC), current version (U//FOUO)
- (l) NGA Risk Evaluation Acceleration Management Process (REvAMP) Matrix, current version (U//FOUO)

ENCLOSURE 2

RESPONSIBILITIES

1. Director, NGA.

a. Appoints, in writing, the Chief Information Officer (CIO), Associate CIO, Chief Information Security Officer (CISO), and Deputy CISO as Agency Authorizing Officials (AOs) to make IS risk management decisions. (References (a) and (b))

b. Retains responsibility for IS risk management decisions. (Reference (a))

c. Appoints, in writing, the CISO as the Agency Senior Accountable Official for Risk Management. (Reference (f))

2. CIO serves as an AO.

3. Associate CIO serves as an AO.

4. CISO.

a. Serves as the Senior Accountable Official for Risk Management.

b. Serves as an AO.

5. Deputy CISO serves as an AO.

6. Senior Accountable Official for Risk Management.

a. Aligns information security and privacy risk management processes with strategic, operational, and budgetary planning processes. (Reference (f))

b. Ensures that managing risk is consistent throughout the Agency, reflects organizational risk tolerance, and is considered along with other types of risk to ensure mission/business success. (Reference (f))

c. Ensures that risk considerations for ISs, including authorization decisions for those systems and the common/hybrid security controls inherited by those systems, are viewed from an Agency-wide perspective regarding Agency strategic goals and objectives in carrying out the Agency's core missions and business functions. (Reference (f))

d. Coordinates with senior leaders and executives to: (Reference (f))

(1) Develop and implement an organization-wide IS risk management strategy that provides a strategic view of IS security risks for the Agency and that guides and

informs organizational IS risk decisions (including how risk is framed, assessed, responded to, and monitored over time);

(2) Provide a comprehensive, Agency-wide, holistic approach for addressing IS risk—an approach that provides a greater understanding of the integrated operations of the Agency;

(3) Establish Agency-wide forums to consider all types and sources of IS risk (including aggregated risk);

(4) Establish effective vehicles and serve as a focal point for communicating and sharing IS risk information among key stakeholders (e.g., authorizing officials and other senior leaders) internally and externally to the Agency;

(5) Ensure that authorization decisions consider all factors necessary for mission and business success; and

(6) Ensure that shared responsibility for supporting Agency missions and business functions using external providers receives the needed visibility and is elevated to appropriate decision-making authorities.

7. AOs.

a. Develop and publish guidance for the Agency's implementation of the RMF. (Reference (j))

b. Authorize ISs of all impact levels into operation. (Reference (a))

c. Document and track IS assessment and authorization activities. (Reference (j))

d. Ensure that ISs are categorized, assigned security controls and control parameters, and operated at an acceptable level of risk. (References (d), (h), and (k))

e. Oversee the assignment and tailoring of security control baselines for ISs requiring assessment and authorization.

f. Review and approve/disapprove PM and ISO requests for security control exceptions.

g. Ensure that requests for exceptions to security controls are justified and documented in a plan of action and milestones (POA&Ms).

h. Assign appropriate weight to competing equities of mission and security requirements, budget consequences, operational performance efficiencies, schedule requirements, counterintelligence concerns, information sharing, civil liberties and

privacy protection, and other relevant policy requirements to determine an acceptable level of risk for authorizing an IS. (Reference (a))

i. Appoint, in writing, Delegated Authorizing Officials (DAOs) to make risk management decisions for moderate or low-impact ISs. (Reference (a))

j. Appoint CCPs to provide and maintain ESS solutions as common or hybrid security control solutions for enterprise ISs. (References (b) and (g))

k. Maintain Reference (k) as the authoritative source for NGA's security control baselines, organizationally defined control parameters, and designation of security controls as common, hybrid, or system-specific. (Reference (j))

8. DAOs.

a. Authorize moderate or low-impact ISs into operation, and execute other tasks designated by an AO. (Reference (a))

b. Collaborate with PMs and ISOs to assign and tailor security control baselines derived from Reference (k) for ISs requiring authorization approval. (References (j) and (l))

c. Collaborate with PMs and ISOs to ensure that ISs are categorized, assigned security controls and control parameters, and operated at an acceptable level of risk. (References (d), (h), and (k))

d. Collaborate with PMs and ISOs to develop system security plans and system security test plans. (References (b), (f), and (j))

e. Collaborate with PMs and ISOs to determine risk associated with acquisition, security relevant changes, recapitalizations, or redesigns prior to the IS being placed into, or returning to, an operational status.

f. Draft and assign POA&Ms to PMs and ISOs for managing IS security deficiencies or approved exceptions.

g. Assign appropriate weight to competing equities of mission and security requirements, budget consequences, operational performance efficiencies, schedule requirements, counterintelligence concerns, information sharing, civil liberties and privacy protection, and other relevant policy requirements to determine an acceptable level of risk for authorizing an IS. (Reference (a))

h. Document and track IS assessment and authorization activities. (Reference (j))

9. Director, CIO and Information Technology Services (D/CIO-T).

a. Acquires, operates, and maintains ESS solutions as common or hybrid security controls for enterprise ISs. (References (b) and (k))

b. Ensures that CCPs, under D/CIO-T purview, provide and maintain ESS solutions as common or hybrid security controls to enterprise ISs. (Reference (k))

10. Director, Security and Installations (D/SI).

a. Acquires, operates, and maintains physical security, personnel security, and environmental services infrastructure to support common or hybrid security controls. (Reference (k))

b. Ensures that CCPs, under D/SI purview, provide and maintain ESS solutions as common or hybrid security controls to enterprise ISs. (Reference (k))

~~11. Chief, NGA Operations Center Mission Assurance, assists Directorate Heads and Agency Element (AE) Leads to accurately determine recovery time objectives and recovery time capabilities for ISs. (Reference (k))~~

~~12. Directorate Heads and AE Leads Component Heads.~~

a. Ensure that CCPs under their purview provide and maintain ESSs and common and/or hybrid security controls to enterprise ISs. (Reference (k))

b. Ensure compliance within their ~~Directorate or AE Component~~ with this Instruction.

13. CCPs.

a. Provide and maintain ESS solutions as common or hybrid security controls for enterprise ISs.

b. Maintain and publish ESS guidance for the integration and implementation of common or hybrid security controls for enterprise ISs.

c. Notify ~~Directorate Heads and AE Leads Component Heads~~, AOs, DAOs, PMs, and ISOs when an ESS common or hybrid security control solution is degraded or not available.

14. PMs and ISOs.

a. Obtain AO or DAO authorizations for all ISs prior to being placed into operation.

b. Maintain IS authorizations at the approved level of risk throughout the operational life cycle.

c. Collaborate with DAOs to ensure that ISs are categorized, assigned security controls and control parameters, and operated at an acceptable level of risk. (References (d), (h), and (k))

d. Collaborate with DAOs to develop system security plans and system security test plans. (References (b), (f), and (j))

e. Collaborate with DAOs to determine risk associated with acquisition, security relevant changes, recapitalizations, or redesigns prior to the ISs being placed into, or returning to, an operational status.

f. Collaborate with DAOs to assign and tailor security control baselines derived from Reference (k) for ISs requiring assessment and authorization approval. (References (j) and (l))

g. Use POA&Ms to manage IS security control deficiencies and approved security exceptions.

h. Submit requests for IS security control exceptions to AO for review and approval/disapproval.

i. Ensure that IS requests for security control exceptions are documented and justified in the ISs POA&M.

j. Assign Information System Security Engineers (ISSEs).

k. Assign Information System Security Officers (ISSOs).

l. Develop, submit, publish, and maintain authorization packages for ISs throughout their operational life cycle. (References (f) and (j))

m. Ensure sanitization compliance with Reference (i).

15. ISSEs conduct information system security engineering activities in support of RMF requirements. (Reference (j))

16. ISSOs ensure that the appropriate security posture is maintained for an IS in support of RMF requirements. (Reference (j))

GLOSSARY

Authorization Package	The essential information that an authorizing official uses to determine whether to authorize the operation of an information system or the provision of a designated set of common controls. At a minimum, the authorization package includes an executive summary, system security plan, privacy plan, security control assessment, privacy control assessment, and any relevant plans of action and milestones. (Reference (f))
Authorization to Operate	The official management decision given by a senior federal official or officials to authorize operation of an information system and to explicitly accept the risk to agency operations (including mission, functions, image, or reputation), agency assets, individuals, other organizations, and the nation based on the implementation of an agreed-upon set of security and privacy controls. Authorization also applies to common controls inherited by agency information systems. (Reference (f))
Authorizing Official (AO)	A senior (federal) official or executive with the authority to formally assume responsibility for operating an information system at an acceptable level of risk to organizational operations (including mission, functions, image, or reputation), organizational assets, individuals, other organizations, and the nation. (Reference (e))
Chief Information Security Officer (CISO)	Official responsible for carrying out the chief information officer (CIO) responsibilities under the Federal Information Security Management Act (FISMA) and serving as the CIO's primary liaison to the agency's authorizing officials, information system owners, and information systems security officers. (Reference (e))
Common Control Provider (CCP)	An organizational official responsible for the development, implementation, assessment, and monitoring of common controls (i.e., security controls inherited by information systems). (Reference (e))

Note: NGA has multiple CCPs.

Delegated Authorizing Official (DAO)	A federal employee appointed by the AO to expedite authorization approval of designated systems and provide mission support for low- to moderate-impact systems. (Reference (a))
Enterprise Security Service (ESS)	A collection of flexible, customizable, and scalable security services and processes that can be applied to protect the processing and transportation of the Agency's data. (Definition created by NGA for NGA purposes only.)
Information Assurance Requirements Catalog (IARC)	Specifies the Agency-defined criteria (parameters) for each of the security controls, control enhancements, and derivative requirements. The IARC categorizes the controls, control enhancements, and related requirements as to whether they are common, system, or hybrid. This document does not replace CNSSI 1253 and its overlays, or NIST SP 800-53. (Definition created by NGA for NGA purposes only.)
Information System (IS)	A discrete set of information resources organized for the collection, processing, maintenance, use, sharing, dissemination, or disposition of information. (Reference (e))
Information System Impact Level—High	The potential impact is high if the loss of confidentiality, integrity, or availability could be expected to have a severe or catastrophic adverse impact on organizational operations, organizational assets, or individuals. Examples of a severe or catastrophic adverse impact are losses of confidentiality, integrity, or availability that might cause any of the following: (a) Degradation in mission capability to an extent and duration that the organization is not able to perform one or more of its primary functions; (b) Major damage to organizational assets; (c) Major financial loss; or (d) Significant harm to individuals involving loss of life or serious life-threatening injuries. (Reference (a))

Information System Impact
Level—Low

The potential impact is low if the loss of confidentiality, integrity, or availability could be expected to have a limited adverse impact on organizational operations, organizational assets, or individuals. Examples of a limited adverse impact are losses of confidentiality, integrity, or availability that might cause any of the following:

(a) Degradation in mission capability to an extent and duration that the organization is able to perform its primary functions, but the effectiveness of the functions is noticeably reduced; (b) Minor damage to organizational assets; (c) Minor financial loss; or (d) Minor harm to individuals. (Reference (a))

Information System Impact
Level—Moderate

The potential impact is moderate if the loss of confidentiality, integrity, or availability could be expected to have a serious adverse impact on organizational operations, organizational assets, or individuals. Examples of a serious adverse impact are losses of confidentiality, integrity, or availability that might cause any of the following:

(a) Degradation in mission capability to an extent and duration that the organization is able to perform its primary functions, but effectiveness of the functions is reduced significantly; (b) Significant damage to organizational assets; or (c) Significant harm to individuals that does not involve loss of life or serious life-threatening injuries. (Reference (a))

Program Manager (PM) and
Information System Owner
(ISO)

An individual responsible for the overall design, build, procurement, development, test, integration, modification, operation, maintenance, and disposal of an information system (as well as the system components), including development and provision of the security plan. (Definition created by NGA for NGA purposes only.)

Risk Management	The program and supporting processes to manage information security risk to organizational operations (including mission, functions, image, reputation), organizational assets, individuals, other organizations, and the nation, and includes: (a) establishing the context for risk-related activities; (b) assessing risk; (c) responding to risk once determined; and (d) monitoring risk over time. (Reference (e))
Risk Management Framework (RMF)	A structured approach used to oversee and manage risk for an enterprise A disciplined and structured process that integrates information security, privacy, and risk management activities into the system development life cycle. (Reference (e))
Senior Accountable Official for Risk Management	The senior official, designated by the head of each agency, who has vision into all areas of the organization and is responsible for alignment of information security management processes with strategic, operational, and budgetary planning processes. (Reference (f))